

(d) MAPEO DETALLADO DE CADA PREGUNTA A REQUISITOS NORMATIVOS

Nº Pregunta	Bloque / Tema	Referencia ENS / IMC / Marco relacionado	Justificación del mapeo
5-7	Alcance y categorización ENS	ENS RD 311/2022: Política de seguridad, categorización de sistemas; Proceso de adecuación CCN. [web:26][web:19]	Determinan si se han ejecutado los pasos iniciales de categorización y alcance exigidos en el plan de adecuación ENS.
8-10	Política y organización de la seguridad	ENS: Política de seguridad, organización de la seguridad; ISO/IEC 27001 (cláusulas contexto y liderazgo). [web:26][web:36]	Evalúan la existencia de política formal y estructura organizativa de seguridad, requisitos básicos del ENS.
11-13	Declaración de Aplicabilidad (DoA)	ENS Anexo II, DoA; Guías de adecuación ENS.[web:26][web:19][web:38]	La DoA es pieza clave del proceso ENS; su implantación y seguimiento son requisitos para demostrar conformidad.
14-16	Análisis de riesgos	ENS: análisis de riesgos; ISO/IEC 27005; NIS2 (gestión de riesgos).[web:26][web:19][web:12]	Miden el grado de implantación de la gestión de riesgos en coherencia con ENS y marcos de riesgo.
17-19	Cuadro de mando e indicadores ENS	ENS: informar sobre el estado de seguridad; proyecto INES (métricas e indicadores).[web:16][web:19]	Evalúan el cumplimiento del mandato de informar sobre estado de seguridad mediante métricas.
20-21	Adopción del modelo IMC	Diccionario de Indicadores para Mejora de la Ciberresiliencia (IMC) de INCIBE.[web:27][web:35]	Determinan si se utiliza el modelo nacional de indicadores de ciberresiliencia recomendado para sectores esenciales.
22-25	Metas de ciberresiliencia (A,R,Rec,E)	IMC: metas Anticipar, Resistir, Recuperar, Evolucionar; modelos de evaluación IMC. [web:27][web:33]	Miden el uso de indicadores por meta de ciberresiliencia según la estructura conceptual del IMC.

26-27	Gestión de vulnerabilidades	ENS: medidas de protección; IMC dominios de gestión de vulnerabilidades; buenas prácticas KPIs. [web:27][web:21]	Analizan la existencia de indicadores de vulnerabilidades, alineados con medidas ENS y métricas IMC.
28-31	Detección y respuesta (MTTD/MTTR)	IMC: indicadores de detección y respuesta; marcos KPIs/KRIs para CISOs.[web:27] [web:20][web:21]	Corresponden a indicadores clave de desempeño operativo recomendados internacionalmente.
32-34	Registro de incidentes e impactos	ENS: gestión de incidentes; IMC: indicadores de incidentes; marcos de reporte a alta dirección.[web:26] [web:27][web:20]	Miden la formalización del registro de incidentes y la estimación de impactos, esenciales para gestión de riesgo.
35-39	Zero Trust y arquitectura	Guías e informes sobre Zero Trust (NIST, industria); ENS: control de acceso, autenticación, monitorización.[web:6] [web:14][web:10] [web:26]	Evalúan el grado de adopción del paradigma Zero Trust y su medición, en coherencia con requisitos de acceso y trazabilidad del ENS.
40-42	Formación y concienciación	ENS: formación y concienciación; IMC: dominios de capacitación; buenas prácticas de ciberresiliencia. [web:26][web:27]	Vinculan la obligación ENS de formación con indicadores públicos de participación y efectividad.
43-45	Continuidad y recuperación	ENS: continuidad del servicio y recuperación; estrategias sectoriales (ej. ciberseguridad del SNS).[web:26][web:30]	Miden la existencia de BCP/DRP y sus pruebas, alineados con los requisitos ENS de disponibilidad y continuidad.
46-48	Riesgo económico y ciberseguro	NIS2/DORA: gestión de riesgo financiero; IMC: indicadores de riesgo; informes globales de riesgo cibernético. [web:12][web:27] [web:11]	Conectan la gestión de riesgos ENS/IMC con la cuantificación económica y el uso de seguros.

49-51	Inversión, IGM y ROI	Marcos de indicadores para CISOs; modelos IMC (indicadores y madurez); prácticas de ROI en ciberseguridad. [web:20][web:27][web:21]	Permiten construir un índice global de madurez y aproximaciones de ROI vinculando inversión e indicadores.
52-54	Alineamiento internacional y auditoría	ENS: auditoría y certificación; ISO/IEC 27001; NIS2, DORA; estrategias de ciberresiliencia UE. [web:26][web:12][web:7][web:15]	Identifican el multi-alineamiento normativo y el grado de verificación externa de las prácticas de seguridad.
55-57	Perspectiva del responsable	Buenas prácticas de reporting a alta dirección (ISMS Forum, consultoras). [web:20][web:12]	Añaden dimensión cualitativa que complementa el cumplimiento normativo con la percepción del responsable.